AI 증강 SIEM 구성도

두 장으로 나눠 그렸습니다. 첫 장은 **어디로 들어와서 어디로 나갔는지**를, 둘째 장은 **로그가 어디서 나와 AI 판단까지 어떻게 흘러가는지**를 답합니다. 한 장에 담으면 둘 다 흐려집니다.

2026-08-26 · rev.3 대상 · 6주차 목표 구성 AWS ap-northeast-2

표 1

서버 일곱 대와 그 위에 올라가는 것

먼저 알아둘 원리가 하나 있습니다. **수집 도구는 자기가 설치된 그 서버만 봅니다.** Wazuh Agent 를 빈 서버에 설치하면 그 서버의 로그만 걷히고, 웹 서버는 아무것도 관측되지 않습니다. 그래서 Agent 와 Client 는 **로그를 만드는 서버마다** 들어가고, 그것을 받는 Manager 와 Server 는 **따로** 둡니다.

서버	설치	인스턴스	역할
웹 서버	nginx · ModSecurity · **Wazuh Agent** · **Velociraptor Client**	`t3.small`	공격 대상. 접근 로그와 WAF 경보를 만든다
네트워크 센서	Suricata · Wazuh Agent · Velociraptor Client	`t3.medium`	미러링된 트래픽을 관측해 `eve.json` 을 만든다
엔드포인트	Windows · **Sysmon** · Wazuh Agent · Velociraptor Client	`t3.small`	호스트 안에서 무엇이 실행되고 무엇이 만들어졌는지를 기록
SIEM	**Wazuh Manager · Indexer · Dashboard**	`t3.large` 이상	로그 수신 · 정규화 · 상관분석 · 경보 생성
DFIR	**Velociraptor Server**	`t3.small`	승인된 조치를 실제로 실행 — 수집 · 격리
LLM (구축 완료)	vLLM · GPT-OSS 20B	`g6e.xlarge`	증거 번들을 받아 판단하고 대응을 제안
공격자 (7주차)	공격 도구	`t3.micro`	공격 발생 · C2 역할

> **Wazuh 와 Velociraptor 는 둘 다 서버·클라이언트 구조입니다.** SIEM 서버와 DFIR 서버가 각각 본체이고, 웹 서버와 네트워크 센서에는 그 클라이언트가 붙습니다. 한 대에 셋을 몰아 설치하면 그 한 대의 로그만 모이고, 정작 공격받는 웹 서버는 관측 밖에 놓입니다.

그림 1

네트워크 구성도

사고가 나면 가장 먼저 펴는 그림입니다. 네트워크 경계가 어디이고, 공격이 어느 문으로 들어와 어느 문으로 나가는지, 각 장비가 어느 구간에 있는지를 봅니다. 상자 안 회색 글씨가 **그 장**

비가 실제로 내보내는 로그입니다.



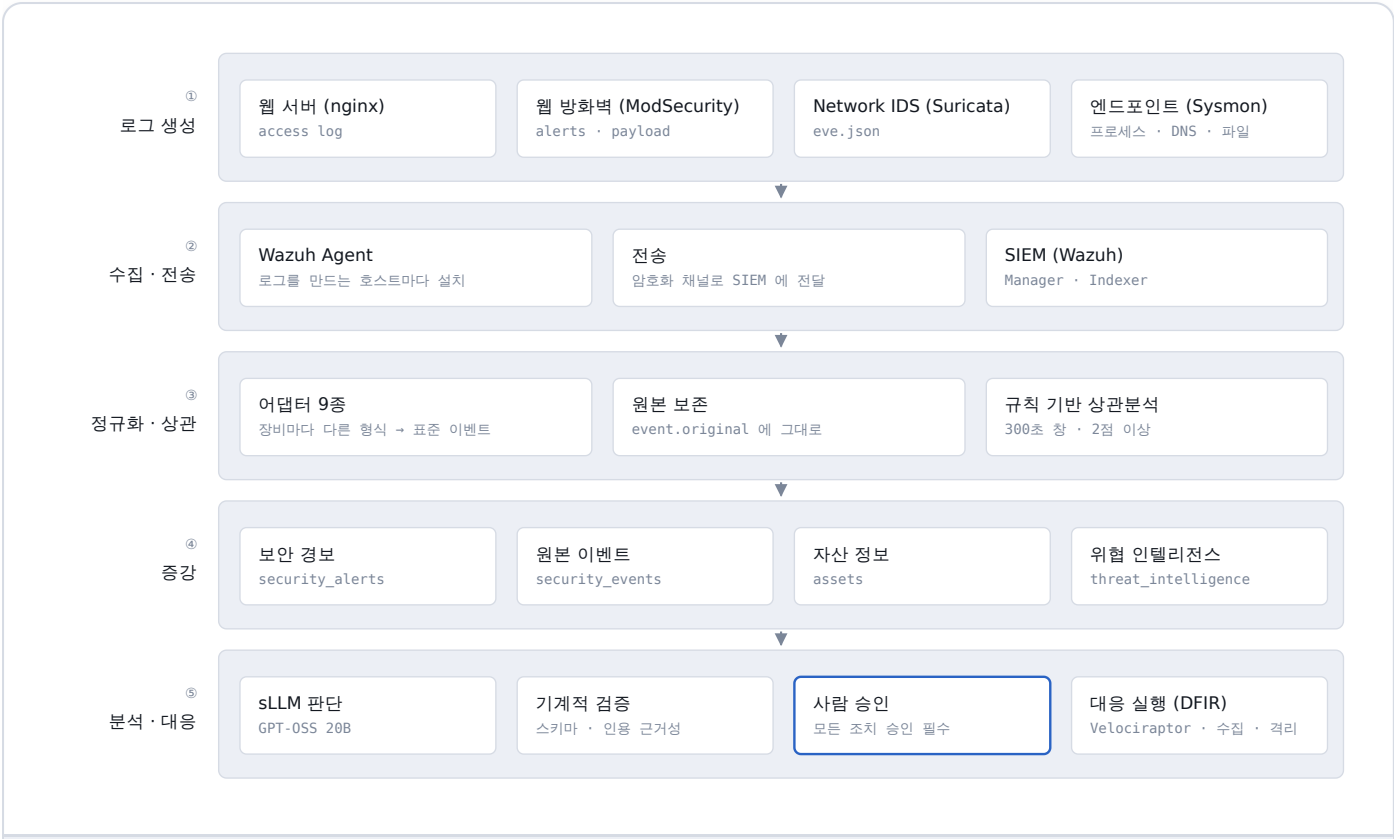
공격은 인터넷 게이트웨이를 거쳐 웹 서버로만 들어옵니다. 프라이빗 서브넷에는 인바운드 규칙이 하나도 없고, 관리자도 SSH 가 아니라 SSM 세션 매니저로만 들어갑니다. 나가는 길은 NAT 게이트웨이 하나뿐이라 침해 후 C2 통신도 그 지점에서 관측됩니다. **DFIR 서버는 사람이 승인한 뒤에만 세 호스트의 클라이언트에 명령을 내립니다.**

> **트래픽 미러링은 구축에서 가장 손이 많이 가는 지점입니다.** AWS 에서는 VPC Traffic Mirroring 을 따로 설정해야 하고, 미러 타겟 · 필터 · 세션을 각각 만들어야 합니다 (`t3` 계열은 Nitro 기반이라 지원됩니다). 막히면 Suricata 를 웹 서버에 함께 설치해 자기 인터페이스를 직접 보게 하는 우회로가 있습니다. **미러링을 먼저 시도하고, 안 되면 우회**하는 순서로 갑니다.

그림 2

계층도 — 로그에서 판단까지

같은 시스템을 **데이터가 지나가는 순서**로 다시 그린 것입니다. 위에서 아래로 한 방향이며, 각 층은 아래층에 넘겨줄 것을 만듭니다. ③층까지는 규칙이 하는 일이고, AI 는 ⑤층에서야 등장합니다.



파란 테두리가 **사람 승인** 관문입니다. sLLM 은 제안만 하고, 승인 없이는 어떤 조치도 실행되지 않습니다. AI 가 호스트를 자동으로 격리하는 구조가 아닙니다.

표 2

어떤 로그를 어디에서 가져오나

두 그림에 흩어져 있는 로그 출처를 한 표로 모았습니다. 발표에서 “이 판단의 근거가 된 로그는 어디서 왔습니까” 라는 질문에 이 표 하나로 답할 수 있어야 합니다.

구간	장비 · 역할	로그	이 로그로 알 수 있는 것
퍼블릭	**웹 서버 (nginx)**	`access log`	어떤 페이지에 어떤 응답 코드가 나갔는지 — 공격이 **통과했는지**의 근거
퍼블릭	**웹 방화벽 (ModSecurity)**	`alerts` · 요청 payload	어떤 공격 패턴이 탐지됐는지, 실제 요청 본문에 무엇이 들어 있었는지
프라이빗	**Network IDS (Suricata)**	`eve.json`	네트워크 수준의 흐름 · DNS · TLS · 시그니처 경보
엔드포인트	**Sysmon**	프로세스 · DNS · 파일	호스트 안에서 무엇이 실행되고 무엇이 만들어졌는지
전 구간	**Wazuh Agent**	위 로그를 전송	로그를 만드는 곳과 모으는 곳을 잇는 유일한 통로
전 구간	**Velociraptor Client**	수집 결과 · 실행 결과	승인된 조사·격리를 실제로 수행하고 그 결과를 돌려준다

> **WAF 와 웹 서버를 함께 봐야 하는 이유.** WAF 가 공격을 탐지했고 웹 서버가 `200` 을 돌려줬다면 **통과한 것**이고, `403` 이나 `404` 라면 막힌 것입니다. 같은 공격 시도라도 대응 우선순위가 완전히 달라지는데, **단일 장비의 경보만으로는 이 구분을 할 수 없습니다.** 상관분석이 필요한 가장 분명한 이유가 여기 있습니다.

표 3

2026-08-25 멘토링 지적 반영

지적	반영
Wazuh Agent 를 웹 서버 / Network IDS **양쪽 하위**에 배치	두 호스트 상자 안에 각각 한 칸씩 넣었습니다
Network IDS 위쪽에 “네트워크 로그를 받아들인다” 표시	웹 서버 호스트에서 내려오는 **트래픽 미러링** 화살표
계층도 + 구성도에 각 로그의 출처 매핑	장비 상자마다 로그 이름을 적고, 표 2 로 한 번 더 정리
표기 수정 — 역할이 앞, 제품명은 괄호	`SIEM (Wazuh)`, `Network IDS (Suricata)`, `DFIR (Velociraptor)`
해킹이 어디로 들어와 어디로 나갔는지	① 인터넷 → IGW → 웹 서버, ② 침해 후 NAT → 외부 C2
로그 전송 에이전트를 별도 컴포넌트로	Agent 를 장비와 분리된 칸으로 표시. **정확한 명칭은 재확인 필요**

확정 필요

이 그림에서 아직 비어 있는 것

- **자산 정보 · 위협 인텔리전스 소스** — 증강 파이프라인이 어디서 받아오는지 그려야 합니다 (abuse.ch 연동 예정).
- **로그 전송 에이전트 명칭** — 멘토링에서 언급된 이름을 재확인해 표기를 맞춰야 합니다.

- **증강 파이프라인과 웹 앱의 위치** — 현재는 각자 노트북에서 도는데, 프라이빗 서브넷 안으로 옮길지 정해야 합니다.
- **전원 그룹** — GPU 는 `lab_running`, 센서·SIEM·DFIR 은 별도 스위치로 나눌 예정입니다.

---

kisia-net / kisi-yaho · 저장소 문서 `docs/STATUS.md`, `docs/MENTORING_LOG.md` 와 함께 봅니다. 구성이 바뀌면 이 그림을 먼저 고치고 인프라를 그다음에 바꿉니다.